Оцінка захищеності інформації в ІКС

Оцінка захищеності інформації в ІКС може відбуватись різними способами. Зокрема, це може бути експертна оцінка (коли аналізуються вимоги НД ТЗІ, або ТЗ на систему, і відповідність реальної ситуації в ІКС цим вимогам, на основі чого робиться висновок про рівень захищеності інформації в ІКС); або оцінка на основі математичного апарату (наприклад, метод на основі теорії нечітких множин та функцій приналежності, вихідними даними для якого є результати опитування персоналу підприємства та експертів, метод 1 (нижче)); або оцінки на основі безопосереднього анкетування співробітників, заповнення чеклістів безпеки (метод 2, нижче).

Непрямими свідками незахищеності інформації можуть бути наявні у системі непропатчені вразливості, слабкості, які описуються існуючими класифікаторами CVE (Common Vulnerabilities and Exposures) та CWE (Common Weakness Enumeration). Особливу небезпеку представляють випадки, коли на відповідні вразливості існують готові експлойти, які їх використовують. Про все це можна дізнатись, використовуючи ресурси типу cvedetails.com.

Також, зробити висновок про захищеність/незахищеність інформації можна на основі ризик-орієнтованого підходу. Великі значення ризиків (добуток імовірності здійснення загрози на величину втрат при здійсненні загрози (вартість та обсяг інформаційних активів мають бути оцінені)) свідчать про низький рівень захищеності інформації. Велика кількість невеликих за обсягом ризиків можуть також свідчити про недостатню відпрацьованість політики безпеки, і відповідно, незахищеність інформації.

МЕТОД 1

Рівень захищеності автоматизованої інформаційної системи визначається по результатам відповідей співробітників підприємства на запропоновані експертами запитання. Попередньо експерти визначають коефіцієнти важливості (КВ) $P_j, j = 1..n$. При цьому використовується метод відносного ранжирування.

<u>Метод відносного ранжирування</u>

Кожні два запитання порівнюються за важливістю, і експерт віддає свій голос одному з них, або може розділяти свій голос між запитаннями у певній пропорції.

Після формування КВ голоси, одержані за кожним запитанням, нормуються по формулі:

$PN_j = \dfrac{P_j}{\sum_{j=1}^{n} P_j}$ таким чином, щоб виконувалось $\sum_{j=1}^{n} PN_j = 1$.

Далі вводиться лінгвістична змінна «рівень захищеності», базова терм-множина якої представлена п'ятьма нечіткими термами $T = \{T_1,...,T_5\}$, які мають назви «низький» (Н), «нижче середнього» (НС), «середній» (С), «вище середнього» (ВС), «високий» (В) [11]. Діапазон зміни параметрів (носителів) X_i, i=1...L (L=5 – кількість термів) можна відобразити на універсальну множину $U = [0,4]$, а функції приналежності $\mu_i, i = 1...L$ визначити так [8]:

$$\mu_i = \frac{1}{1 + (X_i - i + 1)^2}, i = 1...L.$$

В результаті одержуємо такі еталонні нечіткі множини:
H={1.0/0, 0.5/1, 0.2/2, 0.1/3, 0.06/4};
HC={0.5/0, 1.0/1, 0.5/2, 0.2/3, 0.1/4};
C={0.2/0, 0.5/1,1.0/2, 0.5/3, 0.2/4};
BC={0.1/0, 0.2/1, 0.5/2, 1.0/3, 0.5/4};
B={0.06/0, 0.1/1, 0.2/2, 0.5/3, 1.0/4}.

Для побудови показника співробітник повинен відповісти на n запитань по N- бальній шкалі, причому значення N може бути різним для кожного запитання.

Далі діапазон $[\underline{X}_j, \overline{X}_j], (\underline{X}_j = 0, \overline{X}_j = N_j)$ зміни параметра $X_j^*, j = 1..n$ (кількість балів по кожному запитанню) відображається на універсальну множину $U = [0, L-1]$. Перерахунок фіксованого значення $X_j^* \in [\underline{X}_j, \overline{X}_j]$ у відповідний елемент $U_j^* \in [0, L-1]$ виконується за формулою:

$U_j^* = (L-1)\dfrac{X_j^* - \underline{X}_j}{\overline{X}_j - \underline{X}_j}$, а функції приналежності $\mu_i^j(U_j^*), i = 1...L$ нечіткого терма з номером i визначаються так:

$$\mu_i^j(U_j^*) = \left[\frac{1}{1 + (U^*_i - i + 1)^2}\right]^{PN_j}.$$

Далі формується показник рівня захищеності:

$\mu_S(X_j^*) = \bigvee_{i=1}^{L} \bigwedge_{j=1}^{n} \mu_i^j$, $j = 1...L$ -номер терма з базової терм-множини, $j = 1...n$ - номер запитання. Операції $\wedge, \vee$ знаходяться як мінімальне та максимальне значення відповідно по заданій множині значень функції μ_i^j.

<u>Приклад</u>

Нехай є 4 запитання ($n = 4$).
1-ше запитання оцінюється по шкалі 0...3,
2-ге запитання оцінюється по шкалі 0...5,
3-тє запитання оцінюється по шкалі 0...10,

4-те запитання оцінюється по шкалі 0...4.
Визначення важливості запитань проводились групою з 5-ти експертів.

Таблиця 4.1. Коефіцієнти важливості запитань та відповіді співробітників

№ зап.	1	2	3	4	$P_j, j=1...4$	$PN_j, j=1...4$	Відповіді співробітника в баллах $X_j^*, j=1...4$
1	5/5	3,1	3,8	4,8	12,7	0,37	1,5
2	1,9	5/5	3,6	3,9	10,4	0,31	3,5
3	1,2	1,4	5/5	4,2	7,8	0,23	2
4	0,2	1,1	0,8	5/5	3,1	0,09	3,6

В таблиці 4.1 експертами розподіляються їхні 5 голосів між кожними двома відповідями, відповіді співробітника задані (деякі усереднені значення, що одержані за анкетами). Ці дані є вихідними для заповнення таблиці 4.2.

Таблиця 4.2. Функції приналежності та визначення рівня захищеності

№ зап.	U_j^*, $j=1..4$	$\mu_1^j(U_j^*)$	$\mu_2^j(U_j^*)$	$\mu_3^j(U_j^*)$	$\mu_4^j(U_j^*)$	$\mu_5^j(U_j^*)$
1	2					
2	2,8					
3	0,8					
4	3,6					
		$\min_j \mu_1^j$	$\min_j \mu_2^j$	$\min_j \mu_3^j$	$\min_j \mu_4^j$	$\min_j \mu_5^j$
	μ_i, i=1..5					

Далі слід обчислити $\mu_s = \max_i \mu_i$, тоді рівень захищеності відповідає значенню відповідного терма з номером s.

МЕТОД 2.

Розглянемо модель комплексної оцінки системи захисту інформації яка допомагає проаналізувати ступінь виконання вимог до системи захисту.

Спочатку нам необхідно розробити повну, якісну анкету, яка дозволить повноцінно оцінити ступінь виконання певних вимог у інформаційній системі.

Відповідні чеклісти, чи анкети, можуть містити тисячі запитань, отже, для того щоби структурувати процес розробки, пропонується наступний підхід.

Розглянемо декілька блоків показників , які характеризують систему захисту інформації в інформаційній системі:

- Блок показників "Основи";
- Блок показників "Напрямки";
- Блок показників "Етапи".

Розглянемо вміст кожного з блоків.

Основи (O_i, i=1..4):

- O_1: Нормативно-правова та наукова база;
- O_2: Структура та завдання органів захисту;
- O_3: Організаційні заходи та правила (політика безпеки);
- O_4: Програмно-технічні засоби.

Напрямки (H_j, j=1..5)

- H_1: Захист об'єктів корпоративних систем;
- H_2: Захист процесів, процедур та програм обробки інформації;
- H_3: Захист каналів зв'язку;
- H_4: Придушення побічних електромагнітних випромінювань;
- H_5: Керування системою захисту;

Етапи (E_k, k=1..7)

- E_1:Виявлення інформації, що підлягає захисту;
- E_2: Виявлення множини загроз та каналів витоку інформації;
- E_3:Проведення оцінки вразливостей та ризиків за умов E_2;
- E_4: Визначення вимог до системи захисту інформації;
- E_5: Вибір засобів захисту інформації та їх характеристик;
- E_6: Втілення та організація використання обраних засобів та заходів захисту;
- E_7:Здійснення контролю цілісності та керування системою захисту інформації.

В кожній окремій КСЗІ кожен із вищенаведених показників кожного із блоків може бути розгорнутий у більш детальну сукупність конкретних показників.

Описова модель оцінки системи захисту інформації може бути представлена у вигляді поєднання блоків показників у матрицю, яка містить К елементів, де для розглянутої кількості показників у кожному із блоків

К= 4*5*7=140 елементів.

За кожним із елементів матриці експерти можуть сформулювати запитання та проставити оцінку.

В залежності від етапу робіт можна сформувати декілька матриць, однакових за структурою, але різних за змістом.

Наприклад, за елемент із координатами 321 (що відповідає показнику проведення оцінки вразливостей та ризиків (№3 блока «Етапи») ,

показнику захисту програм та процесів (№2 блока «напрямки») та показнику нормативної бази (№ 1 блока «Основи»)) можна формувати із відповідних матриць (в залежності від етапу робіт):

- Матрицю повноти та якості станів елементів КСЗІ;
- Матрицю вимог до КСЗІ;
- Матрицю оцінок ефективності функціонування елементів КСЗІ.

Наведемо приклади запитань за матрицею повноти та якості для елементів 321,322, 323, 324:

123: «Наскільки повно відображені у нормативній та методологічній базі питання оцінки ризиків та вразливостей для інформації, що обробляється в конкретній ІС?»

223: «Чи функціонує служба (співробітники), відповідальні за проведення оцінки ризиків та вразливостей для інформації, що обробляється в даній ІС?»

323: «Чи визначені режимні заходи, які забезпечують своєчасну та якісну оцінку ризиків та вразливостей для інформації, що обробляється в даній ІС?»

423: «Чи застосовуються програмно-технічні засоби для оперативної оцінки ризиків та вразливостей для інформації, що обробляється в даній ІС?»

Таким чином може бути сформульовано 140 запитань (по одному за кожним елементом), відповідаючи на які, експерти ставлять оцінки за певною шкалою. В результаті цих оцінок можна визначити оцінку якості системи захисту інформації за однією із формул:

$$Q = \frac{\sum_{k=1}^{5}\sum_{j=1}^{4}\sum_{i=1}^{7} z_{kji}}{140}; \qquad (1)$$

$$z_{kji} = \begin{cases} 1, q_{kji} > q_{kji}^{d}, \\ 0, q_{kji} \leq q_{kji,}^{d} \end{cases}$$

де q_{kji}^{d} – бажане значення показника якості для відповідного елемента матриці, q_{kji} – одержане за експертною оцінкою значення показника.

Якщо враховувати важливість кожного з елементів матриці, слід використовувати ваги. Однак зважити 140 елементів один стосовно одного досить складно. Тому використовують ваги для стовпців чи рядків матриці, які поєднують блоки елементів.

$$Q = \sum_{k=1}^{5} w_k \sum_{j=1}^{4} w_j \sum_{i=1}^{7} w_i q_{kji}; \qquad (2)$$

де

$$\sum_{k=1}^{5} w_k = 1\,; \sum_{j=1}^{4} w_j = 1\,; \sum_{i=1}^{7} w_i = 1.$$

Розглянемо можливі <u>варіанти експертних оцінок</u>.

1. Якщо вимогу виконано, то $q_{kji} = 1$, якщо ні – то 0. Тоді $Q = \sum_{k=1}^{5}\sum_{j=1}^{4}\sum_{i=1}^{7} q_{kji}/140$; і приймає значення між нулем та одиницею, як і у формулі (1.1).
2. Враховується важливість вимог. Фактично використовується формула (1.2).
3. Ступінь виконання визначається по бальній шкалі:

B_j=5 – відмінно, B_j=4- добре, B_j=3- задовільно, B_j=2- незадовільно, B_j=1- цілком незадовільно. З точки зору виконання вимог відмінно означає – КСЗІ повністю задовольняє вимогам, добре – КСЗІ майже задовольняє вимогам, задовільно – КСЗІ задовольняє вимогам в основному, незадовільно – КСЗІ не задовольняє вимогам, цілком незадовільно – КСЗІ повністю не задовольняє вимогам. Якість КСЗІ визначається середнім балом:

$Q = \sum_{j=1}^{140} B_j/140$. В цьому разі $1 \leq Q \leq 5$.

4. Ступінь виконання визначається бальною шкалою, і одночасно враховується ступінь важливості вимог. Тоді $Q = \sum_{j=1}^{140} w_j B_j/140$, $\sum_{j=1}^{140} w_j = 1$.

Між інтервальними та бальними оцінками, а також лінгвістичними оцінками є відповідність, представлена у таблиці 1.1.

Таблиця 1.1.Відповідність між різними видами оцінок

Бальна оцінка	Лінгвістична оцінка	Інтервальна оцінка
5-відмінно	(В) – повністю відповідає вимогам	0,9-1
4-добре	(ВС) – майже відповідає	0,7-0,9
3-задовільно	(С) – відповідає в основному	0,5-0,7
2-незадовільно	(НС) – не відповідає	0,3-0,5
1-цілком незадовільно	(Н) – повністю не відповідає	0-0,3

В результаті ми можемо визначити якість нашої системи захисту, і , відповідно захищеність інформації, яка обробляється у інформаційній системі.